

O cartigo apresenta uma visão estruturada sobre as atividades essenciais para o desenvolvimento seguro de software, destacando que a segurança deve ser aplicada em todas as etapas do ciclo de vida do sistema. Diante do aumento dos ataques cibernéticos, os autores ressaltam a importância de adotar princípios que garantam confidencialidade, integridade, disponibilidade e não repúdio das informações.

Eles explicam que a segurança é um processo contínuo, que envolve avaliação constante de riscos e redução de vulnerabilidades. Conceitos como perímetro de segurança e superfície de ataque não são fundamentais para controlar acessos e proteger áreas críticas do sistema. O artigo também apresenta 10 práticas essenciais, baseadas na OWASP, como defesa em profundidade, privilégio mínimo, balha segura, simplicidade na segurança e configurações seguras por padrão, entre outras.

O texto aborda ainda a engenharia de requisitos de segurança, a modelagem de ameaças e a necessidade de integrar segurança desde o design até a implementação, aplicando princípios como secure by design e secure by default. São citadas ferramentas e recomendações como OWASP ESAPI e CERT Secure Coding Practices.



Na base de teste, os autores destacam métodos como fuzzing, testes de penetração e análise de código, equilibrando automação e revisão manual. Também são apresentados modelos diversos - Microsoft SDL, CLISF como referências práticas para incorporar segurança no desenvolvimento. Por fim, o artigo conclui que o desenvolvimento seguro depende de colaboração, capacitação contínua e cultura organizacional, sendo uma responsabilidade compartilhada que deve permeiar todo o processo para criar sistemas mais confiáveis e resistentes a ataques.